

SOFTWARE ENGINEERING – PROJECT

RISKTRACE-SOFTWARE SUPPLY-CHAIN RISK ANALYZER

Team

Shaurya Sangwan
(1024030462)

Abhishek Batra
(1024030463)

Sushain Sharma
(1024030439)



Introduction

Software Supply Chain Risk Detector

Modern software applications rely heavily on third-party libraries, open-source packages, and external dependencies.

A single application may depend on hundreds of software components, directly or indirectly.

If one of these components contains a vulnerability, becomes outdated, or is poorly maintained, it can introduce risks to the entire application.

Our project aims to provide a centralized system to analyze and monitor these software dependencies and identify potential risks.



Motivation

Why do we need this?

- Modern applications use a large number of third-party dependencies.
- Developers often cannot manually track all direct and indirect dependencies.
- Vulnerabilities in one dependency can affect the applications that depend on it.
- Outdated or poorly maintained packages can increase software risk.
- Developers need to know which dependencies are risky and which issues should be addressed first.

Example

Our Application → Payment Library → Library A → Vulnerable Library B
Even though the application does not directly use Library B, it can still be affected by its vulnerability.

Problem Statement

Our Problem

How can we automatically analyze a software project's dependency ecosystem, identify potential risks, and help developers prioritize the most critical issues?

Software projects increasingly depend on third-party and open-source components, making it difficult for developers to continuously track the security, reliability, and maintenance risks associated with these dependencies.

Existing approaches may identify known vulnerabilities, but developers still need to understand which dependencies pose the greatest risk to their particular project and should be prioritized for action.

Example

E-commerce App 

→ uses a Payment Library

→ Payment Library uses Library X

→ Library X has a security vulnerability 

Even though the developer never directly used Library X, their application can still be affected.

Proposed Solution

RISHTRACE-Software Supply Chain Risk Detector

We propose a platform that analyzes a project's software dependencies and provides developers with an overall risk assessment.

01.

Workflow

GitHub Repository



Dependency & Project Data Collection



Vulnerability / Dependency Analysis



Risk Assessment



ML-Based Risk Prioritization



Developer Dashboard

02.

Key Features

- Automated dependency analysis
- Direct & indirect dependency identification
- Vulnerability and outdated-package detection
- Risk scoring and prioritization
- ML-based risk prediction
- Explainable risk factors
- Interactive dashboard with recommendations

03.

Proposed Tech Stack

GitHub API | Python | Pandas | Lizard | PostgreSQL | XGBoost | Scikit-learn | SHAP | FastAPI | React.js



THANK YOU